

NexusTech Solutions — Security Policy Overhaul Simulation

Practical Laboratory Report

Field	Detail
Name	Adebukola Olanipekun
Course	GRC102 – Information Security Governance
Module	Module 2 – Developing Security Policies and Procedures
Lab	Week 2 Practical Laboratory
Student Registration No.	C11/26/CGRCE/17603
Date Submitted	16/09/2026
Due Date	18 September 2026

Evidence Bundle 1: Policy Hierarchy and Categorisation

1.1 Hierarchy Definition Table

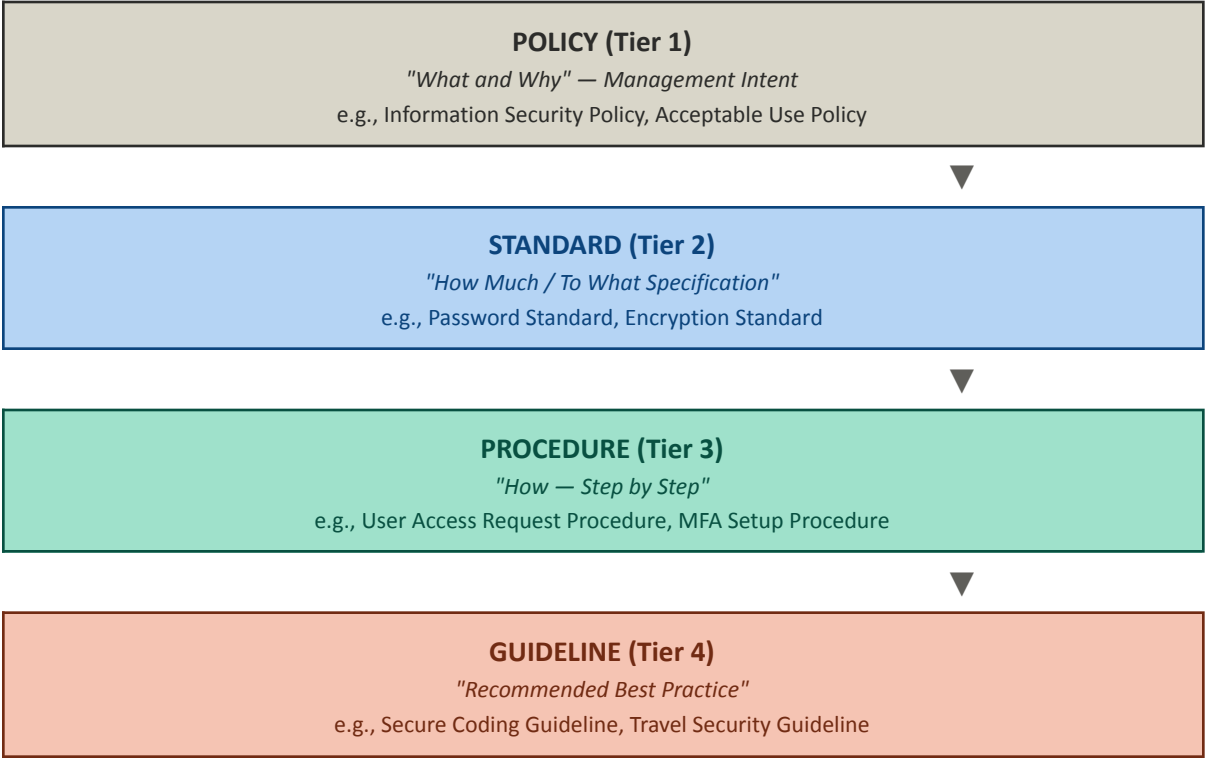
Document Type	Purpose	Authority	Mandatory / Recommended	Level of Detail
Policy	States management's intent, principles, and high-level mandatory requirements. Answers "what" and "why."	Approved by CEO / Senior Management	Mandatory	High-level, broad, enduring
Standard	Specifies measurable technical or operational requirements that support a policy. Answers "how much" or "to what specification."	Approved by Information Security Manager or CISO	Mandatory	Specific, measurable, technical
Procedure	Step-by-step instructions for executing a task or process. Answers "how" in sequence.	Approved by Process Owner	Mandatory for the defined task	Detailed, sequential, operational
Guideline	Recommended best practice or advice. Answers "how best" where strict compliance is not required.	Approved by Policy Owner	Recommended (advisory)	Flexible, explanatory

Authority Hierarchy: Policy > Standard > Procedure > Guideline. A lower-tier document must never contradict a higher-tier document.

1.2 Categorisation of Draft Statements

S/N	Statement	Classification	Justification
1	All NexusTech employees must use MFA when accessing the corporate network remotely.	Policy	States a mandatory high-level requirement ("must") applying to all employees; expresses management intent without technical detail.
2	To configure MFA on your mobile device, download the Authenticator app, scan the QR code, and enter the six-digit code.	Procedure	Sequential, step-by-step instructions for executing a specific task; operational in nature.
3	It is recommended that developers use parameterised queries to reduce SQL injection risk.	Guideline	Advisory language ("recommended"), not mandatory; provides best-practice guidance.
4	NexusTech is committed to protecting the confidentiality, integrity and availability of all client data.	Policy	High-level statement of management intent and commitment; foundational principle.
5	All corporate laptops must have full-disk encryption enabled using BitLocker or FileVault.	Standard	Mandatory ("must") and specifies a measurable technical specification (encryption method).
6	Employees should avoid connecting to public, unsecured Wi-Fi networks when travelling.	Guideline	Advisory language ("should avoid"), not enforceable as a strict requirement.
7	In the event of a suspected security breach, employees must immediately contact the IT Helpdesk.	Procedure	Specifies a mandatory action with a defined step (contact Helpdesk); operational response instruction.
8	Passwords must be a minimum of 14 characters and contain at least one uppercase, one lowercase, one number and one special character.	Standard	Mandatory ("must") and provides precise, measurable password complexity specifications.

1.3 Policy Hierarchy Diagram



Evidence Bundle 2: Acceptable Use Policy

NEXUSTECH SOLUTIONS
ACCEPTABLE USE POLICY

Document Control	
Title	Acceptable Use Policy
Version	1.0
Policy Owner	Information Security Manager

Document Control	
Approval Authority	Oluyemi Agboola, CEO
Effective Date	1 October 2026
Review Date	1 October 2027

1. Purpose

This policy defines the acceptable and prohibited use of NexusTech Solutions' information systems, devices, networks, applications, and data. It aims to protect NexusTech, its employees, clients, and partners from security, legal, and operational risks arising from inappropriate use of corporate resources.

2. Scope

This policy applies to:

- All full-time, part-time, and contract employees of NexusTech Solutions.
- Interns, consultants, and third-party personnel with access to NexusTech resources.
- All company-owned devices (laptops, desktops, mobile phones, tablets).
- Personal devices authorized for business use (BYOD).
- All corporate networks, cloud services, email, collaboration tools, and data.

3. Policy Statements

3.1 Acceptable Use

3.1.1 NexusTech systems and devices shall be used primarily for legitimate business purposes.

3.1.2 Employees may use corporate email, internet, and collaboration tools for incidental personal use, provided such use:

- Does not interfere with job responsibilities.
- Does not consume excessive network or storage resources.
- Does not violate any law, regulation, or company policy.
- Does not expose NexusTech to reputational or legal risk.

3.1.3 Employees must use company-approved software and cloud services only. Installation of unauthorized software on company devices is prohibited.

3.1.4 All users must lock their screens when leaving workstations unattended.

3.1.5 All users must report suspected security incidents to the IT Helpdesk immediately (extension 5555).

3.2 Prohibited Activities

- 3.2.1 Attempting to gain unauthorized access to NexusTech systems, client systems, or third-party networks.
- 3.2.2 Sharing passwords, credentials, or access tokens with any other person.
- 3.2.3 Downloading, installing, or using unlicensed or pirated software.

- 3.2.4 Using corporate resources for illegal activities, harassment, discrimination, or the creation/distribution of malicious content.
- 3.2.5 Storing or transmitting client data on personal, unapproved cloud storage services (e.g., personal Dropbox, Google Drive).
- 3.2.6 Circumventing or disabling security controls, including antivirus, firewalls, or encryption.
- 3.2.7 Connecting company devices to unsecured public Wi-Fi networks without using the corporate VPN.
- 3.2.8 Using corporate email for mass unsolicited communications (spam) or phishing.

3.3 Reasonable Personal Use

3.3.1 Limited personal use of email and internet is permitted during breaks and outside core working hours.

3.3.2 Personal use must not:

- Involve downloading large files unrelated to business.
- Involve streaming media for extended periods.
- Involve accessing adult, gambling, or other inappropriate content.
- Result in additional costs to NexusTech.

3.3.3 NexusTech reserves the right to monitor, access, and review all data stored on or transmitted through its systems, in accordance with applicable laws.

4. Roles and Responsibilities

Role	Responsibility
All Users	Read, acknowledge, and comply with this policy; report violations and incidents.
Managers	Ensure team members understand and comply; approve reasonable personal use exceptions where appropriate.
IT / Security Team	Implement technical controls; monitor compliance; investigate violations; provide awareness training.
HR	Integrate policy into onboarding; support disciplinary processes for violations.
Information Security Manager	Maintain and review this policy; advise on exceptions.

5. Compliance and Enforcement

5.1 Compliance with this policy is mandatory.

5.2 Violations may result in:

- Verbal or written warning.
- Suspension or termination of access privileges.
- Disciplinary action up to and including termination of employment.
- Legal action where applicable.
- Contract termination for third parties.

5.3 NexusTech reserves the right to monitor system usage to ensure compliance with this policy.

6. Exceptions

- 6.1 Exceptions to this policy must be requested in writing using the Exception Request Form.
- 6.2 Exceptions require approval from the Information Security Manager and, where high-risk, the CEO.
- 6.3 Exceptions are valid for a maximum of 6 months and must be reviewed before renewal.

7. Approval and Review

Action	Name	Date
Prepared by	Information Security Manager	3/10/2026
Approved by	Oluyemi Agboola, CEO	4/10/2026
Next Review Date	1 October 2027	

8. Related Documents

- Information Security Policy
- User Access Request Procedure
- Password Standard
- Incident Response Policy
- Data Classification Policy

Evidence Bundle 3: User Access Request Procedure

NEXUSTECH SOLUTIONS

USER ACCESS REQUEST PROCEDURE

Document Control	
Title	User Access Request Procedure
Version	1.0
Procedure Owner	IT Helpdesk Manager
Approval Authority	Information Security Manager
Effective Date	1 October 2026

Document Control	
Review Date	1 October 2027

1. Purpose

This procedure defines the step-by-step process for requesting, approving, and provisioning user access to NexusTech systems. It ensures that all access is formally authorized, follows the principle of least privilege, and is fully auditable.

2. Scope

This procedure applies to:

- All new employee, contractor, and intern access requests.
- Requests for additional access by existing users.
- Access changes (modifications) and revocations.
- All NexusTech systems, applications, and data repositories.

3. Prerequisites

Before initiating an access request, the following must be in place:

- A valid employment or contract record in the HR system.
- A designated manager or data owner authorized to approve access.
- A completed and approved ticket in the IT Service Management (ITSM) system.
- For privileged access: additional approval from the Information Security Manager.

4. Procedure Steps

Step	Action	Responsible	System/Tool
1	Request Initiation: The requester (manager or HR) submits an access request via the ITSM portal using the "Access Request" ticket template. The ticket must include: user name, department, role, systems required, access level, and business justification.	Requester (Manager/HR)	ITSM Portal
2	Ticket Validation: The Helpdesk technician verifies the ticket is complete and that the requester has authority to request access for the named user. Incomplete tickets are returned with a comment.	Helpdesk Technician	ITSM Portal
3	Manager Approval: The Helpdesk routes the ticket to the user's line manager for approval. The manager confirms the access is necessary for the user's role.	Line Manager	ITSM Portal
4	Data Owner Approval: For access to client data or sensitive systems, the Helpdesk routes the ticket to the relevant data owner for additional approval.	Data Owner	ITSM Portal

Step	Action	Responsible	System/Tool
5	Least-Privilege Check: The Helpdesk reviews the requested access against the user's role profile. If the request exceeds the standard role profile, the ticket is escalated to the Information Security Manager for review.	Helpdesk Technician	Role Matrix
6	Account Creation: Upon approval, the Helpdesk creates the user account in Active Directory (or relevant system) using the standard naming convention.	Helpdesk Technician	Active Directory
7	Permission Assignment: The Helpdesk assigns permissions based on the approved role profile. No additional permissions beyond those approved are granted.	Helpdesk Technician	Active Directory / Application
8	MFA Enrollment: The Helpdesk ensures the user enrolls in Multi-Factor Authentication before first login.	Helpdesk Technician	MFA Portal
9	User Notification: The Helpdesk notifies the user and their manager via email that access has been provisioned, including login instructions and security reminders.	Helpdesk Technician	Email
10	Evidence Capture: The Helpdesk attaches all approval records, role profile, and provisioning confirmation to the ticket.	Helpdesk Technician	ITSM Portal
11	Ticket Closure: The Helpdesk closes the ticket with a resolution note confirming access was granted as approved.	Helpdesk Technician	ITSM Portal
12	Record Retention: All access request tickets are retained for a minimum of 3 years for audit purposes.	Helpdesk Manager	ITSM Portal

5. Emergency / Exceptional Requests

5.1 Emergency access requests (e.g., critical incident response) may be granted verbally by the Information Security Manager.

5.2 Verbal approvals must be documented in the ITSM ticket within 24 hours.

5.3 Emergency access is granted for a maximum of 72 hours and must be reviewed and either formalized or revoked after the emergency period.

6. Access Modification and Revocation

6.1 Access modification requests follow the same approval workflow as new requests.

6.2 Access revocation requests (e.g., termination, role change) are processed within 24 hours of notification from HR.

6.3 The Helpdesk disables the account, revokes all permissions, and retrieves company assets.

7. Record Retention and Audit Trail

7.1 All access requests, approvals, and provisioning records are stored in the ITSM system.

7.2 Records are retained for a minimum of 3 years.

7.3 The Information Security Manager conducts quarterly audits of access records to verify compliance with this procedure.

8. Related Documents

- Access Control Policy
- Acceptable Use Policy
- Password Standard
- Privileged Access Management Procedure
- Employee Onboarding/Offboarding Checklist

Evidence Bundle 4: Communication and Training Plan

NEXUSTECH SOLUTIONS

COMMUNICATION AND TRAINING PLAN — Acceptable Use Policy Rollout

Field	Detail
Plan Owner	Information Security Manager
Approved By	Oluyemi Agboola, CEO
Rollout Period	1 October – 15 November 2026

1. Target Audiences, Messages, Channels, and Timing

Audience	Key Message	Channel	Owner	Timing	Acknowledgement	Success Measure
General Employees	"The new AUP protects you and our clients. Know what's acceptable, what's prohibited, and how to report issues."	All-hands meeting; email; intranet article; mandatory LMS module	HR + InfoSec Manager	Week 1: Announcement; Week 2-3: Training; Week 4: Follow-up	LMS acknowledgement + signed attestation	≥95% training completion; ≥95% attestation rate
IT Staff	"You are the enforcers. Understand the AUP in depth, how to monitor compliance, and how to handle violations."	Technical workshop; email; Confluence page	InfoSec Manager + IT Director	Week 1: Workshop; Week 2: Q&A session	Workshop attendance + knowledge check	≥90% knowledge check pass rate
Managers	"You are responsible for your team's compliance. Know how to	Manager briefing; email; manager toolkit	HR + InfoSec Manager	Week 1: Briefing; Week 3: Refresher	Manager attestation	100% manager attestation

Audience	Key Message	Channel	Owner	Timing	Acknowledgement	Success Measure
	approve exceptions and escalate violations."					
Third-Party Contractors	"You must comply with NexusTech's AUP while working with us."	Contract addendum; email; onboarding packet	Legal + InfoSec Manager	Upon contracting; annual reminder	Signed contract addendum	100% signed addendum

2. Rollout Timeline

Week	Activity	Responsible
Week 1 (1-7 Oct)	CEO announcement at all-hands; policy published on intranet; manager briefing	CEO, HR, InfoSec
Week 2 (8-14 Oct)	Mandatory LMS training launched for all employees; IT workshop	HR, InfoSec
Week 3 (15-21 Oct)	Department Q&A sessions; manager refresher; training reminders	InfoSec, Managers
Week 4 (22-31 Oct)	Training completion follow-up; attestation collection	HR
Week 5 (1-7 Nov)	Compliance report to CEO; escalate non-completion	InfoSec Manager
Week 6 (8-15 Nov)	Remedial training for non-completers; final report	HR, InfoSec

3. Acknowledgement / Attestation Mechanism

3.1 All employees must complete the LMS training module and digitally sign the AUP attestation form.

3.2 The attestation confirms: "I have read, understood, and agree to comply with the NexusTech Acceptable Use Policy."

3.3 Attestation records are stored in the HR system and retained for the duration of employment plus 3 years.

3.4 New employees must complete attestation during onboarding, before system access is granted.

4. Measures of Rollout Effectiveness

Metric	Target	Data Source	Frequency	Owner
Training completion rate	≥95%	LMS	Weekly during rollout	HR
AUP attestation rate	≥95%	HR System	Weekly during rollout	HR
Knowledge check pass rate	≥85%	LMS	Upon completion	InfoSec
Helpdesk tickets related to AUP confusion	<10 in first month	ITSM	Monthly	IT Helpdesk
Policy violation reports	Baseline + review	Incident System	Monthly	InfoSec

5. Escalation for Non-Compliance or Repeated Misunderstanding

Level	Trigger	Action	Responsible
Level 1	Employee fails to complete training by deadline	Reminder email; 5-day grace period	HR
Level 2	Employee still non-compliant after grace period	Manager escalation; access restriction warning	Manager + HR
Level 3	Repeated non-compliance or policy violation	Formal disciplinary process; access suspension	HR + InfoSec
Level 4	Serious or willful violation	Termination; legal referral if applicable	CEO + HR

6. Continuous Improvement

- 6.1 Post-rollout survey to gather feedback on training effectiveness.
- 6.2 Quarterly review of violation trends to identify awareness gaps.
- 6.3 Annual refresher training for all employees.

Evidence Bundle 5: Policy Review and Maintenance Memo

NEXUSTECH SOLUTIONS
POLICY REVIEW MEMO

Field	Detail
To	Information Security Steering Committee
From	Information Security Manager
Date	5/10/2026
Subject	Review of Acceptable Use Policy (AUP) – Cloud Migration and Data Sharing Incident

1. Review Triggers

Two significant events require the AUP to be reviewed ahead of its scheduled annual review. First, NexusTech has migrated its primary database to Amazon Web Services (AWS), introducing new cloud-specific risks including shared-responsibility confusion, misconfiguration, and data residency considerations. The current AUP does not address cloud service usage, approved cloud providers, or data storage locations. Second, a minor security incident occurred when an employee shared a sensitive client document through a

personal cloud storage account (personal Dropbox), violating the spirit of the existing policy but not explicitly prohibited by its current wording. This incident exposed a gap in the policy's coverage of personal cloud storage and data exfiltration risks.

2. Review Process

The review will follow the Security Policy Development Lifecycle. I will consult with IT Operations (cloud architecture), Legal (data residency and client contracts), HR (enforcement), and a representative sample of employees (usability). A risk analysis will be conducted to assess the likelihood and impact of cloud-related data exposure, referencing ISO/IEC 27001:2022 A.5.23 (Cloud Services Security) and SOC 2 Trust Services Criteria (Confidentiality and Privacy). Evidence reviewed will include the incident report, AWS configuration baseline, client contract requirements, and current AUP attestation records. The revised policy will be drafted, reviewed by the Steering Committee, and submitted to the CEO for approval. Upon approval, it will be published, communicated, and attested to by all employees within 30 days.

3. Proposed AUP Updates

Update 1 – Cloud Service Usage: Add a new section stating: "Employees shall only use NexusTech-approved cloud services for storing, processing, or sharing company or client data. A list of approved cloud services is maintained by IT Operations. Use of personal cloud storage accounts (e.g., personal Dropbox, Google Drive, iCloud) for company or client data is strictly prohibited."

Update 2 – Data Sharing and Exfiltration Controls: Add a new section stating: "Employees shall not transmit company or client data to external parties without prior approval from their manager and the Information Security Manager. All external data sharing shall use NexusTech-approved secure file transfer methods. Any suspected or accidental data exposure must be reported to the IT Helpdesk immediately."

4. Policy Owner and Approval Route

The policy owner remains the Information Security Manager. The revised version (v1.1) will be reviewed by the Information Security Steering Committee and approved by the CEO, Marcus Vance, in accordance with the existing approval authority.

5. Recommended Review Frequency and Early-Review Triggers

The AUP should continue to be reviewed annually. Early-review triggers should include: (a) significant technology changes such as cloud migration or new system deployment; (b) security incidents involving policy gaps; (c) new legal or regulatory requirements (e.g., client contractual changes, data protection laws); (d) changes to ISO/IEC 27001 or SOC 2 requirements; and (e) repeated policy violations indicating unclear or unenforceable language. This memo recommends that the revised AUP be approved by [Insert Date] and communicated to all staff within 30 days of approval.

Prepared by: Information Security Manager, Isabelle Annumudu

Date: 6/10/2026

References

ISO/IEC 27001:2022 – Information security, cybersecurity and privacy protection – Information security management systems – Requirements.

ISO/IEC 27002:2022 – Information security controls.

NIST Cybersecurity Framework 2.0 (2024).

AICPA SOC 2 Trust Services Criteria (2017, updated 2022).